



Actividad | #2 |

Prevención de Fuentes de Ataques e Intrusión

Seguridad Informática I

Ingeniería en Desarrollo de Software



TUTOR: Sin Tutor

ALUMNO: Oscar Esteban Sánchez Leyva

FECHA: 26/Agosto/2026

ÍNDICE

ÍNDICE	2
INTRODUCCIÓN	3
DESARROLLO	4
TABLA DE RECOMENDACIONES	4
ANÁLISIS DE FUENTES DE ATAQUE.....	7
LOS PRINCIPALES RIESGOS	9
CONCLUSIÓN.....	11
REFERENCIAS.....	12

INTRODUCCIÓN

En la **primera actividad** se llevó a cabo un análisis de las vulnerabilidades y amenazas de una institución educativa en Veracruz. Durante este análisis se identificaron riesgos de origen humano, lógico, físico, de almacenamiento y comunicación. Entre los problemas críticos detectados se encontraban el uso de contraseñas débiles como "1234abc", un firewall deshabilitado, antivirus gratuito, internet sin restricciones y software de origen desconocido en el servidor secundario.

En esta **segunda actividad**, asumo el rol de analista de seguridad con el objetivo de prevenir posibles fuentes de ataques e intrusiones. Cada vulnerabilidad identificada anteriormente puede ser explotada por diversos vectores de ataque, tales como ingeniería social, keyloggers, ransomware, ataques de denegación de servicio (DoS), envenenamiento DNS, inyección SQL, entre otros. Por ello, es esencial proponer medidas de protección, mejora y monitoreo que reduzcan la probabilidad de que estas amenazas se conviertan en realidad.

Este documento presenta recomendaciones detalladas para cada amenaza detectada, relacionando cada una con la fuente específica de ataque que podría aprovechar tal debilidad. El objetivo es reforzar la confidencialidad, integridad y disponibilidad de la información institucional.

DESARROLLO

TABLA DE RECOMENDACIONES

Categoría	Factor de Riesgo / Amenaza	Recomendación para proteger/mejorar/monitorear	Fuente de Ataque e Intrusión que podría ocasionar
Amenazas humanas	Acceso no autorizado por personal interno	Implementar control de acceso basado en roles (RBAC), cuentas individuales con MFA y registro de auditoría con SIEM. Revisión trimestral de privilegios según principio de mínimo privilegio (NIST SP 800-53 AC-2).	Escalada de privilegios, movimiento lateral y acceso a BD académica. Exfiltración de datos.
Amenazas humanas	Uso inadecuado de los equipos (redes sociales, WhatsApp)	Establecer Política de Uso Aceptable (AUP), filtrado web con proxy, y DLP para bloqueo de sitios de riesgo. Capacitación mensual en higiene digital.	Phishing, ingeniería social, descarga de malware y keylogger vía enlaces maliciosos.
Amenazas humanas	Ingeniería social	Programa de concientización contra phishing con simulacros (ej. KnowBe4), validación de identidad por doble canal y protocolo de reporte de correos sospechosos.	Phishing, vishing, spear-phishing. Robo de credenciales y compromiso de correo (BEC).
Amenazas humanas	Robo o pérdida de credenciales (1234abc)	Política de contraseñas robustas: mínimo 12 caracteres, complejidad, gestor de contraseñas institucional (Bitwarden) y MFA obligatorio. Rotación cada 90 días y bloqueo tras 5 intentos fallidos.	Ataque de fuerza bruta, credential stuffing y keylogger. Acceso a sistemas críticos y bases de datos.
Amenazas humanas	Instalación de software no autorizado	Aplicar AppLocker / políticas de lista blanca, cuentas sin privilegios de administrador local y solución EDR para bloqueo de ejecutables desconocidos.	Instalación de troyanos, spyware y ransomware. Puerta trasera (backdoor).
Amenazas lógicas	Malware o virus (solo NOD32 gratuito)	Migrar a solución EDR empresarial (Defender for Endpoint, CrowdStrike) con protección en tiempo real, análisis heurístico y sandbox. Actualización automática de firmas cada hora.	Ransomware, gusano de red, keylogger y criptominero que compromete disponibilidad.
Amenazas lógicas	Acceso mediante contraseñas débiles	Implementar autenticación con Active Directory + política de complejidad + MFA. Usar hash bcrypt/Argon2 en BD y monitoreo de credenciales filtradas con HaveIBeenPwned API.	Ataque de diccionario, inyección SQL si se usan credenciales débiles en aplicaciones. Compromiso de BD.
Amenazas lógicas	Software de procedencia desconocida en Servidor 2	Realizar auditoría forense del servidor 2, desinstalar software no verificado, reinstalar desde fuentes oficiales con verificación hash SHA256. Implementar control de integridad con Tripwire.	Supply chain attack, backdoor y rootkit. Persistencia avanzada (APT).
Amenazas lógicas	Ataques provenientes de Internet (Firewall deshabilitado)	Habilitar y configurar firewall de próxima generación (NGFW) con reglas de entrada/salida, IPS/IDS y bloqueo geo. Configurar pfSense / Fortinet con registro de logs.	Escaneo de puertos, DoS/DDoS, explotación de vulnerabilidades y DNS spoofing / cache poisoning.
Amenazas lógicas	Pérdida o corrupción de información	Estrategia de respaldo 3-2-1: 3 copias, 2 medios, 1 offsite en la nube cifrada. Respallos diarios incrementales y semanales completos con prueba de restauración mensual.	Ransomware con cifrado destructivo, wiper y pérdida por error humano. Ataque a BD.

Categoría	Factor de Riesgo / Amenaza	Recomendación para proteger/mejorar/monitorear	Fuente de Ataque e Intrusión que podría ocasionar
Amenazas físicas	Incendio	Instalar detectores de humo, extintores tipo CO2 para equipos electrónicos, sistema de rociadores y protocolo de evacuación. Mantener servidores en rack ignífugo.	Destrucción física que causa DoS físico y pérdida total de disponibilidad de servicios y BD.
Amenazas físicas	Sismos	Anclaje antisísmico de racks y servidores, UPS con apagado automático y plan de continuidad de negocio (BCP) con sitio alternativo.	Caída de infraestructura, corrupción de discos y DoS por desastre natural.
Amenazas físicas	Inundaciones o daños por fenómenos naturales (cercanía a costa)	Elevar centro de cómputo por encima del nivel de inundación, barreras anti-agua, impermeabilización y respaldo en nube en región diferente.	Fallo de hardware masivo, cortocircuito y pérdida de datos por daño físico.
Amenazas físicas	Robo de equipos (laptops, servidores)	Control de acceso biométrico a centro de cómputo, cámaras CCTV 24/7, jaulas de seguridad para servidores, inventario RFID y cifrado de disco completo (BitLocker).	Robo de información, extracción de disco y acceso offline a BD. Data breach físico.
Amenazas físicas	Daño accidental (golpes, derrames)	Normas de manejo de equipo, protectores, mesas con canalización de líquidos y capacitación. Uso de carcasas ruggedizadas.	Pérdida accidental de integridad y disponibilidad. Corrupción de almacenamiento.
Vulnerabilidades de almacenamiento	Poco espacio disponible / lentitud	Implementar monitoreo con Zabbix/Nagios para alertas de disco >80%, políticas de limpieza automática, ampliación a NAS/SAN y almacenamiento en la nube.	DoS por agotamiento de recursos, caída de BD y fallo en escritura de logs que facilita intrusión encubierta.
Vulnerabilidades de almacenamiento	Falta de respaldos suficientes	Automatizar respaldos con Veeam Backup, retención GFS y almacenamiento inmutable contra ransomware. Verificación de integridad con checksum.	Ransomware sin posibilidad de recuperación. Pérdida irreversible por ataque a BD.
Vulnerabilidades de almacenamiento	Concentración de información en servidores (servidor principal)	Implementar alta disponibilidad con clúster, replicación síncrona a servidor espejo y base de datos distribuida. Balanceo de carga.	Punto único de fallo (SPOF). Si se compromete, ataque total a BD y secuestro de información.
Vulnerabilidades de almacenamiento	Software desconocido en servidor 2 (vulnerabilidad de integridad)	Aislar servidor 2 en cuarentena, análisis con sandbox y reemplazo por imagen dorada (golden image) certificada. Gestión de parches con WSUS.	Persistencia de malware, exfiltración de BD por canal encubierto y puerta trasera.
Categoría	Factor de Riesgo / Amenaza	Recomendación para proteger/mejorar/monitorear	Fuente de Ataque e Intrusión que podría ocasionar
Vulnerabilidades de comunicación	Equipos conectados directamente al módem (planta baja)	Diseñar red estructurada: módem en modo puente -> router/firewall -> switches administrables. Desactivar DHCP del módem y usar NAT controlado.	Man-in-the-Middle (MitM), sniffing de credenciales y ataque de envenenamiento ARP/DNS.
Vulnerabilidades de comunicación	Uso de Wi-Fi insuficientemente protegido	Implementar WPA3-Enterprise con RADIUS, contraseñas de 16+ caracteres, SSID oculto para administración y segmentación de invitados. Monitoreo de rogue AP.	Evil Twin, deautenticación, sniffing y keylogger vía Wi-Fi. Acceso no autorizado a red interna.
Vulnerabilidades de comunicación	Firewall deshabilitado	Habilitar firewall en todos los endpoints y perimetral, reglas de denegación por defecto, inspección profunda de paquetes y logs centralizados en SIEM (Wazuh).	Intrusión externa, explotación de puertos abiertos, DoS y pivoting hacia BD.
Vulnerabilidades de comunicación	Uso sin restricciones de Internet	Implementar proxy con filtrado de categorías (FortiGate), DNS filtrado (Quad9), bloqueo de .exe y lista negra de dominios maliciosos. Política de navegación.	Drive-by download, phishing, cryptojacking y descarga de keylogger/RAT.
Vulnerabilidades de comunicación	Falta de segmentación de red	Crear VLANs: Administrativa (VLAN 10), Académica (VLAN 20), Servidores (VLAN 30), Invitados (VLAN 99) con ACLs y firewall inter-VLAN. Implementar Zero Trust.	Movimiento lateral, propagación de ransomware y acceso a BD desde red de alumnos. Ataque DNS interno.

En resumen, la tabla identifica los riesgos de seguridad informática, describe cómo prevenirlos y detalla el tipo de ataque que podrían provocar si no se abordan adecuadamente.

EXPLICACIÓN SENCILLA

Categoría	¿Qué significa?	¿Cómo se protege?	¿Qué podría pasar?
Amenazas humanas	Errores o acciones maliciosas de personas.	Control de accesos, MFA, capacitación y políticas.	Robo de información, phishing, acceso no autorizado.
Amenazas lógicas	Problemas relacionados con software, virus o configuraciones.	Antivirus/EDR, actualizaciones, firewall y monitoreo.	Malware, ransomware, robo de datos, ataques a servidores.
Amenazas físicas	Daños físicos a equipos e instalaciones.	Cámaras, extintores, protección de servidores y planes de emergencia.	Pérdida de equipos, datos y disponibilidad del servicio.
Vulnerabilidades de almacenamiento	Problemas por falta de espacio, respaldos o concentración de	Respaldos, almacenamiento adicional y servidores redundantes.	Pérdida de datos, caída de sistemas y ransomware.
Vulnerabilidades de comunicación	Problemas en la red, Wi-Fi, Internet o firewall.	VLAN, WPA3, firewall, VPN, filtrado y segmentación.	Interceptación de información, intrusión y movimiento lateral.

La finalidad subyacente de la tabla es la siguiente:

- Identificar riesgos → implementar medidas de protección → realizar seguimiento → impedir el ingreso, propagación o sustracción de información por parte de un atacante.

Ejemplo específico:

- Contraseña débil → implementación de autenticación multifactor (MFA) y fortalecimiento de contraseñas → monitoreo constante → prevención del acceso no autorizado a cuentas y bases de datos.

Otro ejemplo:

- Red no segmentada → creación de VLANs y aplicación de ACLs (listas de control de acceso) → control del tráfico → prevenir el movimiento lateral de un atacante desde la red estudiantil hacia los servidores.

Estas recomendaciones se orientan a salvaguardar tres elementos clave: **la**

confidencialidad de la información, su integridad y la disponibilidad de los sistemas.

ANÁLISIS DE FUENTES DE ATAQUE

- **Ingeniería social y phishing:** La ausencia de políticas de uso y la exposición a redes sociales convierten a la ingeniería social en un vector de ataque probable. Un atacante podría enviar un correo con un enlace malicioso que instale un keylogger para capturar contraseñas débiles como "1234abc", lo que le permitiría acceder a la base de datos de calificaciones y a datos personales.
- **Malware y ransomware:** Utilizar un antivirus gratuito y tener el firewall desactivado facilita la intrusión de ransomware tipo LockBit. Este cifraría el servidor principal donde se almacena toda la información, ocasionando una pérdida total en caso de no contar con respaldos inmutables. La fuente de ingreso podría ser una descarga involuntaria durante la navegación sin restricciones.
- **Ataques a la base de datos:** Las contraseñas poco seguras y la falta de segmentación de redes simplifican las inyecciones SQL y el acceso directo a la base de datos MySQL/PostgreSQL del sistema académico. Un atacante interno podría utilizar credenciales genéricas como "Equipo1" para modificar calificaciones.
- **Ataques de red (DNS y MitM):** Con los dispositivos conectados directamente al módem y un Wi-Fi sin WPA3, se facilitan los ataques de ARP spoofing y DNS spoofing. Un atacante en la misma red podría redirigir el tráfico hacia un sitio falso y robar credenciales mediante un keylogger de red.

- **Denegación de servicio (DoS):** La falta de espacio en disco y la inexistencia de un firewall propician un DoS por agotamiento de recursos. Un atacante podría saturar el almacenamiento con logs falsos o iniciar un SYN Flood desde Internet, dejando fuera de servicio el portal de la universidad.
- **Amenazas físicas como vector de intrusión:** El robo de una laptop sin cifrado BitLocker permite extraer el disco y acceder a información confidencial offline, resultando en una violación grave de la Ley de Protección de Datos debido a una data breach.

Estas amenazas pueden mitigarse con un modelo de defensa en profundidad que incluye capas físicas, de red, de endpoint y humanas, en alineación con ISO 27001 y el NIST Cybersecurity Framework.

LOS PRINCIPALES RIESGOS

1. **Acceso no autorizado:** Alguien obtiene permisos no adecuados, lo que podría comprometer información académica o bases de datos.
2. **Uso inapropiado de equipos:** Visitar sitios web peligrosos o descargar archivos puede introducir malware.
3. **Ingeniería social:** Un atacante engaña a una persona para conseguir contraseñas o información confidencial.
4. **Contraseñas débiles:** Pueden facilitar ataques de fuerza bruta y el robo de cuentas.
5. **Software no autorizado:** Puede instalar troyanos, spyware o ransomware en los equipos.
6. **Malware/virus:** Capaz de dañar archivos, sustraer información o bloquear sistemas enteros.
7. **Firewall deshabilitado:** Expone la red a ataques provenientes de Internet.
8. **Falta de respaldos:** En caso de un ataque de ransomware o daño, los datos pueden perderse para siempre.
9. **Incendios, sismos e inundaciones:** Pueden destruir físicamente servidores y otros equipos importantes.
10. **Robo de equipos:** Una laptop o un servidor robado puede dar acceso a información si no está cifrado adecuadamente.
11. **Escaso espacio de almacenamiento:** Puede causar lentitud, errores y caídas en bases de datos.

12. **Servidor principal como único punto de fallo:** Un error o ataque al servidor principal puede dejar el sistema inoperativo.
13. **Conexión directa al módem:** Incrementa el riesgo de interceptaciones y ataques a la red.
14. **Wi-Fi inseguro:** Permite vulnerabilidades como Evil Twin, espionaje y acceso no autorizado.
15. **Internet sin restricciones:** Facilita actividades como phishing, malware y descargas peligrosas.
16. **Red sin segmentación:** Un atacante puede moverse fácilmente desde una computadora comprometida hacia servidores y bases de datos críticos.

CONCLUSIÓN

La Actividad 2 muestra que cada vulnerabilidad identificada previamente puede ser una vía de acceso para ataques específicos. No es suficiente con identificar el riesgo; es crucial conectarlo con su método de explotación real: una contraseña débil no es solo un "riesgo", sino una invitación al uso de fuerza bruta y keylogging; un firewall desactivado abre las puertas a ataques DoS y envenenamiento DNS.

Las recomendaciones sugeridas aplican el principio de defensa en profundidad y el modelo de confianza cero. Esto incluye segmentar la red en VLANs, usar autenticación multifactorial (MFA), emplear sistemas EDR, seguir la estrategia de respaldos 3-2-1 y ofrecer formación continua contra tácticas de ingeniería social. De esta forma, la institución educativa de Veracruz puede adoptar una postura más proactiva en lugar de reactiva, asegurando la confidencialidad, integridad y disponibilidad de su información crítica, un recurso valioso tanto para estudiantes como para el personal administrativo.

Implementar estas medidas disminuye considerablemente la superficie vulnerable a ataques y previene que amenazas como ransomware, inyección SQL o robo físico se conviertan en incidentes críticos de seguridad.

REFERENCIAS

- ¿Qué es un sistema de prevención de intrusiones (IPS)? (2025, agosto 20). *Ibm.com*.
<https://www.ibm.com/mx-es/think/topics/intrusion-prevention-system>
- ¿Qué es un IPS (Sistema de Prevención de Intrusiones)? | Fortinet. (s. f.). Fortinet.
<https://www.fortinet.com/lat/resources/cyberglossary/what-is-an-ips>
- Trend Micro - Mexico (MX). (s. f.-a). ¿Cuáles Son las Medidas para la Seguridad de Redes? Trend Micro. https://www.trendmicro.com/es_mx/what-is/network-security/network-security-measures.html
- Robinette, D. (s. f.). *What is an Example of an Intrusion Prevention System?*
<https://www.stamus-networks.com/blog/what-is-an-example-of-an-intrusion-prevention-system>
- Fair, L. (2026, 15 enero). *Intrusion Detection and Prevention Systems and Techniques*. American Military University. <https://www.amu.apus.edu/area-of-study/information-technology/resources/intrusion-detection-and-prevention-systems-and-techniques/>